CHAPTER 6

DECENTRALISED IDENTITY AND AUTHORITY TRUST

6.1 Introduction

In the last chapter, we presented the research architecture and the trust-centric consent model, in which patient consent is created as the evaluable object C = (I, A, P, T, L, E). The identity component I of that object names the patient, the authorised doctor and the guardian set G, but naming a participant does not establish who that participant is or what that participant may do. A key attribute of a trustworthy authorisation decision is that identity and authority are distinct: a participant who can be identified is not thereby authorised, and a participant who holds a credential is not thereby the participant named in the consent (Mazzocca et al. 2025). Hence, it is important that the identity of a participant and the authority that the participant holds are verified as separate conditions before the participant takes part in a consent decision or requests healthcare data.

In this chapter, building on the consent object presented in the last chapter, we present a decentralised method to verify the identity and the authority of a participant. In our work, we use decentralised identifiers coupled with verifiable credentials to model and verify who a participant is and which role the participant holds, and the result of this verification is the predicate VI of the authorisation decision; this provides a complete solution to research objective 2. In this chapter, we also present the results of the validation of the proposed solution to research question two, using the HALAH prototype introduced in Chapter 5.

This chapter is described as follows: In Section 6.2, we provide a detailed explanation of decentralised identifiers, verifiable credentials, and the credential store and trusted-issuer registry of the prototype. In Section 6.3, the principle that identity is not authorisation and the verification condition VI are presented, and Section 6.4 shows the identity and authority verification workflow. Furthermore, Section 6.5 provides the step-by-step procedure and Algorithm 2 required to carry out the verification. Section 6.6 describes how the verification is realised in the prototype and the steps of its working, the proposed solution is validated in Section 6.7, while Section 6.8 concludes this chapter.

6.2 Decentralised Identifiers and Verifiable Credentials

A decentralised identifier (DID) can be defined as a globally unique identifier that is created and controlled by its subject without a central registration authority, and that resolves to a DID document holding the cryptographic material needed to verify the controller of the identifier (W3C 2022). In basic terms, a DID gives a participant an identity reference that no single healthcare institution owns, while a verifiable credential (VC) gives a participant a signed statement about an attribute, such as a professional role, that any party can verify from the signature of the issuer (W3C 2025). Today, DIDs and VCs are being applied in different fields, among them healthcare, education and

government identity, so that a holder can present claims made by one issuer to another verifier (Mazzocca et al. 2025). In this thesis, the two are used together: the DID answers the question of who the participant is, and the VC answers the question of what the participant may do.

6.2.1 Decentralised Identifiers

A DID is a string with three parts separated by colons: the scheme did, the DID method, and the method-specific identifier (W3C 2022). For example, the identifier did:hospital:001 used in the prototype has the method hospital and the method-specific identifier 001. The method defines how an identifier is created, resolved, updated and deactivated. Resolving a DID returns its DID document, which lists the verification methods, such as public keys, by which the controller of the DID proves control of it, and may list the service endpoints at which the controller can be reached (W3C 2022). Figure 6.1 shows this structure.

In this thesis, a DID is the identity reference of every participant. The patient, the authorised doctor and each guardian are named in the consent object by their DIDs, and the DID of a requester is the identity against which the credential of Section 6.2.2 is checked. In the current prototype a DID is checked for its syntax, and the resolution of the DID document is reserved for the next stage, as Section 6.6 explains.

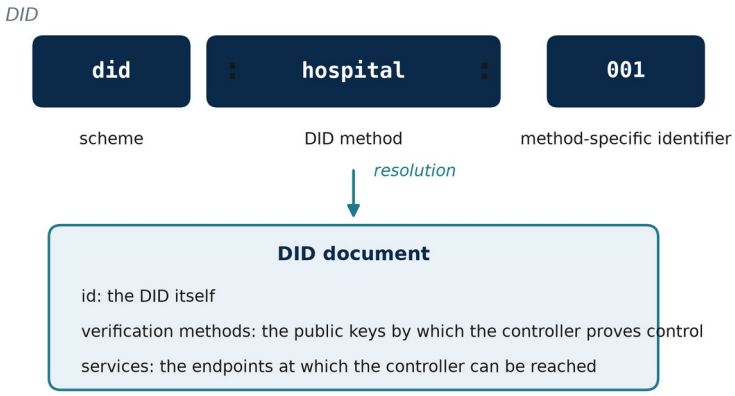


Figure 6.1: Structure of a decentralised identifier and its DID document (after W3C 2022)

6.2.2 Verifiable Credentials

A verifiable credential is a set of claims made by an issuer about a subject, together with a proof that lets a verifier check that the claims were made by that issuer and have not been altered (W3C 2025). Three roles take part. The issuer signs the credential and gives it to the holder, the holder keeps the credential and presents it, and the verifier checks the proof and the claims (W3C 2025). The data model defines, among other properties, the issuer, the validity period validFrom and validUntil, the credentialSubject, which holds the identifier of the subject and the claims about it, and the proof (W3C 2025).

In this study, the credential is a role credential: it states that the subject DID holds the role doctor or guardian and names the organisation of the holder, if any. The credential used by the prototype follows this structure, as Figure 6.2 shows, and its proof is an EIP-712 typed-data signature of the issuer (Bloemen, Logvinov & Evans 2017), so the same signature scheme serves the credentials of this chapter and the guardian approvals of Chapter 7. A credential is taken to be valid only when its signature verifies, its issuer is trusted, its subject is the DID that presents it, and the time of the check lies inside its validity period; the role claim is then compared with the role that the step requires.

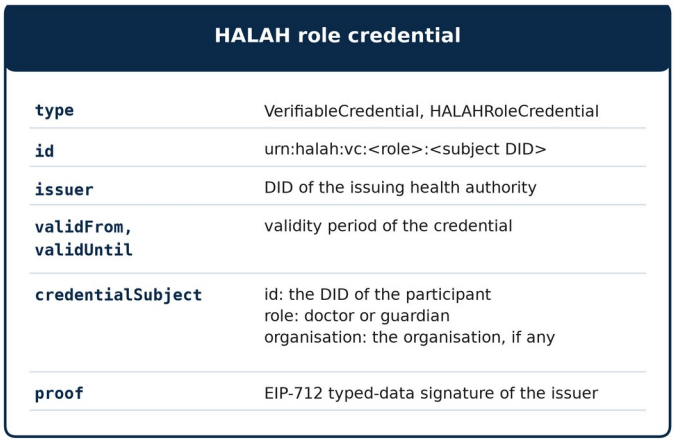


Figure 6.2: Structure of the role credential used by the prototype

6.2.3 Credential Store and Trusted Issuers

The verification of Section 6.5 relies on two stores. The credential store holds the credential of each participant DID and stands in for the wallet of the holder at this stage of the prototype. The trusted-issuer registry maps the DID of each accepted issuer to the address to which its credential signatures must recover. A credential from an issuer that is not in the registry fails the issuer condition, and a credential whose signature recovers to another address fails the signature condition, so the two conditions are checked separately and recorded separately. In the current prototype, the registry holds one demo issuer, did:halah:issuer:demo-health-authority, and the credential store holds the credentials of four guardians and three doctors, from which the two guardians and the two doctors of the demonstrations are drawn. The key of the demo issuer can be reproduced from the source code, so the check demonstrates the verification steps and not the secrecy of the issuer key, as Chapter 5 noted.

6.3 Overview of Decentralised Identity and Authority Trust

RO2 addresses RQ2 by developing a decentralised identity and authority verification mechanism using Decentralised Identifiers and Verifiable Credentials. The objective is to establish trustworthy participants while separating identity authentication from authorisation authority. RO2 provides the trust inputs required by the subsequent multi-party authorisation process. The objective is based on the principle that successful identity verification does not automatically imply permission to access healthcare data. The central principle of RO2 is Equation (6.1).

$$\text{Identity} \neq \text{Authorisation}. \tag{6.1}$$

A valid DID provides an identity reference, while a valid VC provides evidence associated with a participant's role, authority, or other relevant attribute. Neither mechanism should automatically grant access to patient data. Instead, the verified identity and authority information become inputs to the subsequent authorisation process. The identity and authority verification condition can be expressed as Equation (6.2), where u is the requesting participant and $\text{Authority}(u, C)$ establishes whether the verified authority matches the role required by the consent. The DID verification process establishes whether the identity reference is valid. In the current prototype this check is structural, as Section 6.6 explains. The VC verification process establishes whether the participant possesses valid authority evidence. The final authorisation decision remains dependent on the consent requirements and access policy.

$$V_I(u) = \text{VerifyDID}(u) \wedge \text{VerifyVC}(u) \wedge \text{Authority}(u, C). \tag{6.2}$$

6.4 Identity and Authority Verification Workflow

The workflow begins when a participant attempts to participate in the consent process or requests access to healthcare data. The system resolves and verifies the participant's DID and then retrieves the associated VC. The credential is checked for validity and its claims are examined to determine whether the participant possesses the authority required by the consent. In the HALAH implementation, the Guardian workflow uses a selected guardian DID and invokes VC verification before adding the guardian's signature to the consent. As shown in Figure 6.3, the output of RO2 is not an access-grant decision. It is a verified identity and authority result that can be consumed by RO3 and RO4. This separation prevents a participant from obtaining access merely by presenting a valid identity credential.

Figure 6.3 shows the target design of the workflow. Full DID resolution is planned for the next stage, whereas the current prototype performs a DID-format check, a check of a demo-issuer credential and EIP-712 signature recovery, as Section 6.6 explains.

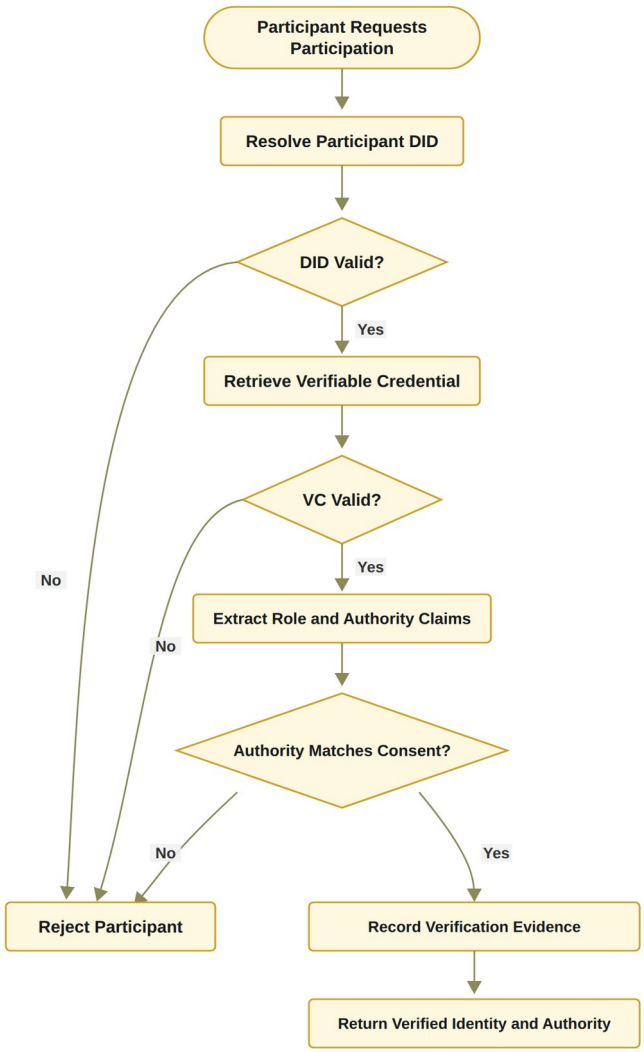


Figure 6.3: RO2 workflow for decentralised identity and authority verification

6.5 Verification Model and Algorithm

The proposed solution to Objective 2 is grounded in the decentralised identifiers and verifiable credentials of Section 6.2. The verification combines three checks, the identifier, the credential and the authority that the credential gives for the consent at hand, into the single predicate VI of Equation (6.2). Section 6.5.1 presents the procedure step by step, and Section 6.5.2 formalises it as Algorithm 2, which the prototype of Section 6.6 implements.

6.5.1 Step-by-Step Procedure for DID and VC Identity and Authority Verification

The procedure below is the one defined for this objective. It is presented in full so that the reader can understand the working of Algorithm 2, which formalises it in Section 6.5.2.

The DID and VC Identity and Authority Verification procedure determines whether a participant possesses a valid decentralised identity and sufficient verifiable authority to participate in the consent-defined authorisation process. The procedure establishes a verifiable relationship between the participant u, the identity information represented by the DID, the attributes contained in the associated VC, and the authority requirements specified by the consent object C. The procedure consists of the following steps.

Step 1 – Resolve the Participant's DID. The system first resolves the decentralised identifier (DID) associated with participant u. DID resolution retrieves the DID-related information required to establish the participant's decentralised identity and identify the corresponding DID document. If the DID cannot be successfully resolved, the verification process terminates and returns INVALID.
Step 2 – Verify the DID Document. After successful resolution, the system verifies the DID document and its associated identity information. The verification process determines whether the document is structurally valid and whether the relevant cryptographic information, such as verification methods and public keys, can be trusted for subsequent credential verification. A failed DID verification results in an INVALID outcome.
Step 3 – Retrieve the Participant's Verifiable Credential. The system retrieves the verifiable credential (VC) associated with participant u. The VC provides machine-verifiable claims concerning the participant, such as professional role, organisational affiliation, or delegated authority. If an appropriate VC cannot be retrieved, the participant cannot establish the required authority and the verification process returns INVALID.
Step 4 – Verify the Verifiable Credential. The retrieved VC is cryptographically and semantically validated. The system verifies the credential signature, issuer, subject, and validity conditions. In particular, the system determines whether the credential was issued by an acceptable issuer, whether it refers to the current participant, whether its signature is valid, and whether the credential remains within its validity period. Formally, the credential can be considered valid only when $VC_{valid} = Sig_{VC} \wedge Issuer_{valid} \wedge Subject_{match} \wedge Time_{valid}$. If any of these conditions fails, the verification process returns INVALID.
Step 5 – Extract Role and Authority Claims. Once the VC has been successfully verified, the system extracts the relevant role and authority claims associated with participant u. Depending on the healthcare scenario, these claims may identify a doctor, guardian, researcher, auditor, or another authorised participant. The extracted claims provide the evidence required for determining whether the participant satisfies the authority requirements of the consent object.
Step 6 – Compare Authority Claims with Consent Requirements. The extracted role and authority claims are compared against the authorisation requirements A specified in the consent object C. The purpose of this step is to ensure that possession of a valid identity or credential is not automatically interpreted as permission to access healthcare information. The authority verification condition can therefore be represented as $Authority(u, C) = Claims(u) \models A_C$, where $Claims(u)$ denotes the verified claims associated with participant u, and A_C denotes the authority requirements defined by consent object C. If the participant's claims do not satisfy the required authority conditions, the system returns INVALID.

Step 7 – Establish Identity–Authority Binding. After the claims have satisfied the consent requirements, the system establishes the binding between the verified participant identity and the corresponding authority. This step ensures that the authority being exercised is associated with the same participant whose DID and VC have been successfully verified, thereby reducing the possibility of an unrelated credential being used to obtain access.
Step 8 – Record Identity and Authority Evidence. The system records the evidence generated during the verification process. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, verification timestamp, and the relationship between the verified claims and the consent requirements. This evidence provides an auditable basis for subsequent access-authorisation decisions.
Step 9 – Return the Verification Result. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns $VI(u) = VALID$. Otherwise, the procedure terminates at the first failed mandatory verification condition and returns $VI(u) = INVALID$.
The overall verification process can therefore be represented as $DID_{resolve} \rightarrow DID_{verify} \rightarrow VC_{retrieve} \rightarrow VC_{verify} \rightarrow Claims_{extract} \rightarrow Authority_{match} \rightarrow Evidence_{record} \rightarrow VI(u)$.

The procedure establishes an important separation between identity verification and authority verification. A participant is not considered valid merely because a DID can be resolved or because a VC has a valid cryptographic signature. Instead, the participant must demonstrate that the verified credential claims satisfy the authority requirements associated with the specific consent object C.

Consequently, the procedure can be interpreted as a two-layer verification mechanism $Identity(u) \wedge CredentialValidity(u) \wedge Authority(u, C) \Rightarrow VI(u) = VALID$.

6.5.2 Algorithm 2: DID and VC Identity and Authority Verification

Algorithm 2 formalises the procedure. If DID resolution, DID verification, VC retrieval, VC verification, and authority validation are all successfully completed, the system returns $V_I(u) = VALID$. Otherwise, the procedure terminates at the first failed mandatory verification condition and returns $V_I(u) = INVALID$. The system records the evidence. The evidence may include the resolved DID, verification status, credential identifier, issuer information, relevant authority claims, and verification timestamp. This evidence provides an auditable basis for subsequent access-authorisation decisions.

Algorithm 2 DID and VC Identity and Authority Verification

Require: Participant u, consent object C
Ensure: Verification result $V_I(u) \in \{VALID, INVALID\}$, where VALID corresponds to $V_I(u) = 1$

1: Resolve DID of u
2: **if** DID resolution fails **then**
3: **return** INVALID
4: **end if**
5: Verify DID document and associated identity information
6: **if** DID verification fails **then**
7: **return** INVALID
8: **end if**
9: Retrieve VC associated with u
10: **if** VC retrieval fails **then**
11: **return** INVALID
12: **end if**
13: Verify VC signature, issuer, subject, and validity
14: **if** VC verification fails **then**
15: **return** INVALID
16: **end if**
17: Extract role and authority claims from VC
18: **if** claims do not satisfy the authority requirements of C **then**
19: **return** INVALID
20: **end if**
21: Record identity and authority verification evidence
22: **return** VALID

Algorithm 2 establishes that identity verification and authority verification are related but distinct operations. A participant may possess a valid DID while lacking the authority required by the consent. Similarly, a credential may be structurally valid but irrelevant to the specific authorisation requirement. Therefore, the algorithm verifies both credential validity and authority relevance. This mechanism turns identity and authority claims into verifiable evidence. However, it does not independently establish collective consent or policy compliance. Those conditions are evaluated by RO3 and RO4 (Chapters 7 and 8).

6.6 Prototype Implementation

6.6.1 Realisation in the Prototype

RO2 has been completed at the conceptual and prototype level. The current implementation demonstrates the separation between participant identity and authorisation authority. A valid healthcare participant identity can be verified independently from the question of whether that participant is authorised to access a particular patient's data. Each credential used by the prototype comes from a demo issuer, and the check covers the four conditions of VC_{valid}, namely the signature, issuer, subject and validity time, together with the role claim. The doctor and guardian credentials are checked when the consent is created. Each guardian's credential is checked again before the guardian signs, as Section 6.4 describes, and the doctor's credential is checked again at each access request, where the DID that the doctor enters must also be the doctor named in the consent. V_I in the current prototype combines this doctor check with EIP-712 verification of the signature of each listed guardian, and its outcome is recorded in the audit ledger. A request that fails V_I is refused before any data is released, and the refusal is recorded. An invalid or forged credential is also refused (attack scenario A12). Because the demo issuer key can be rebuilt from the source code, this check shows the verification steps, not the secrecy of the issuer key. The prototype also derives each guardian's signing key from the guardian DID. Full DID resolution against a registry (Algorithm 2, lines 1 to 8), proof that the user controls the DID entered,

and wallet-held keys are acknowledged limitations reserved for the next stage. The validation evidence for RO2, including the scenarios and the unit-level adversarial tests, is presented in Section 6.7.

6.6.2 Steps in the Working of the Prototype for Identity and Authority Verification

In order to verify a participant, the HALAH prototype carries out the following steps at two points of the workflow: when a guardian approves a consent, and when a doctor requests data. The same service functions are called at both points, so the check that the guardian interface applies is the check that the doctor interface applies. The steps involved are as below:

1. Get the DID and its credential: The DID of the participant is taken from the interface, for a guardian from the list of guardians of the consent and for a doctor from the DID entered, and the credential of that DID is read from the credential store.
2. Check the identifier: The DID is checked against the syntax did:method:identifier, and a malformed identifier fails the check.
3. Verify the credential: The four conditions of VC^valid| are evaluated one by one: the signature against the registered address of the issuer, the issuer against the registry, the subject against the DID presented, and the validity period against the clock of the server.
4. Match the role and bind to the consent: The role claim must be guardian for an approval and doctor for a request, and the DID of the doctor must be the authorised doctor named in the consent.
5. Record the evidence and return VI: The credential identifier and the issuer are written to the audit ledger with the approval, and the DID and credential of the requester with every decision. A guardian who fails the check cannot sign, and the refused approval is recorded; a doctor who fails VI is refused before the scope of the consent or any record is shown, and the refused request is recorded.

The logical working of the above steps is shown pictorially in Figure 6.4. Figure 6.5 shows the guardian interface after step 5 for the guardian did:parent:A, with the credential verified and the signature added, and Figure 6.6 shows the doctor interface for a requester who holds a valid doctor credential but is not the doctor named in the consent, where VI fails and the request is refused and recorded.

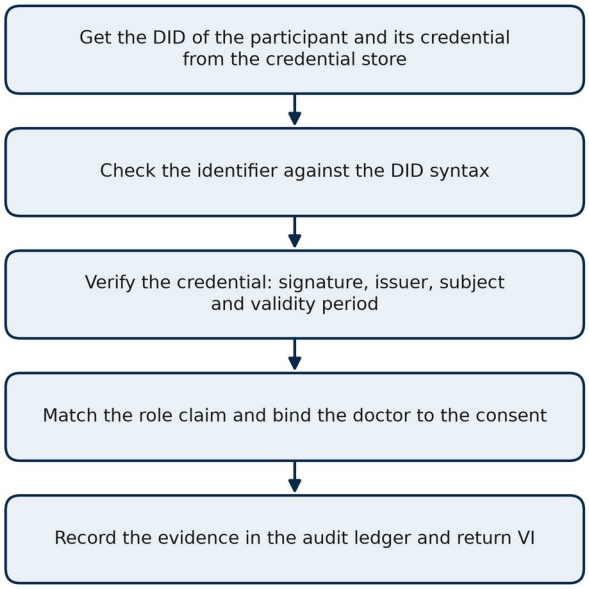


Figure 6.4: Steps of the prototype for verifying the identity and the authority of a participant

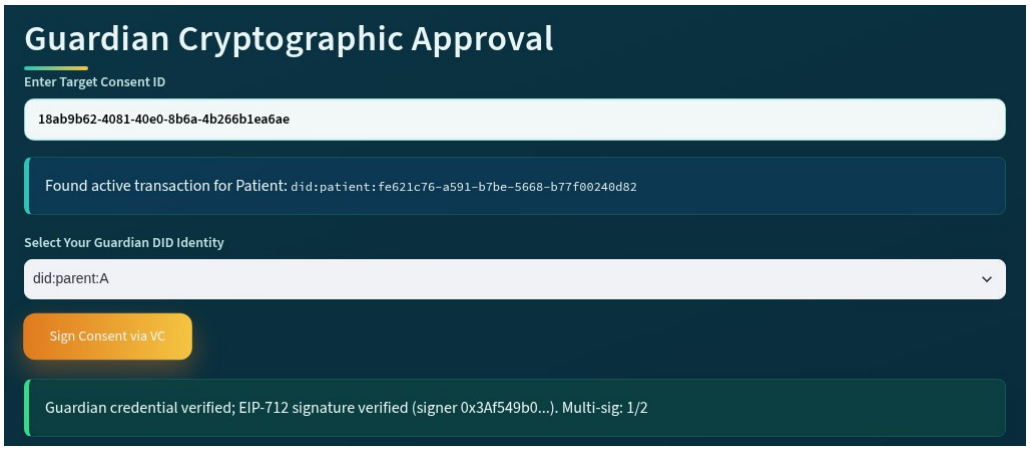


Figure 6.5: Guardian interface after the credential of did:parent:A has been verified and the approval signed

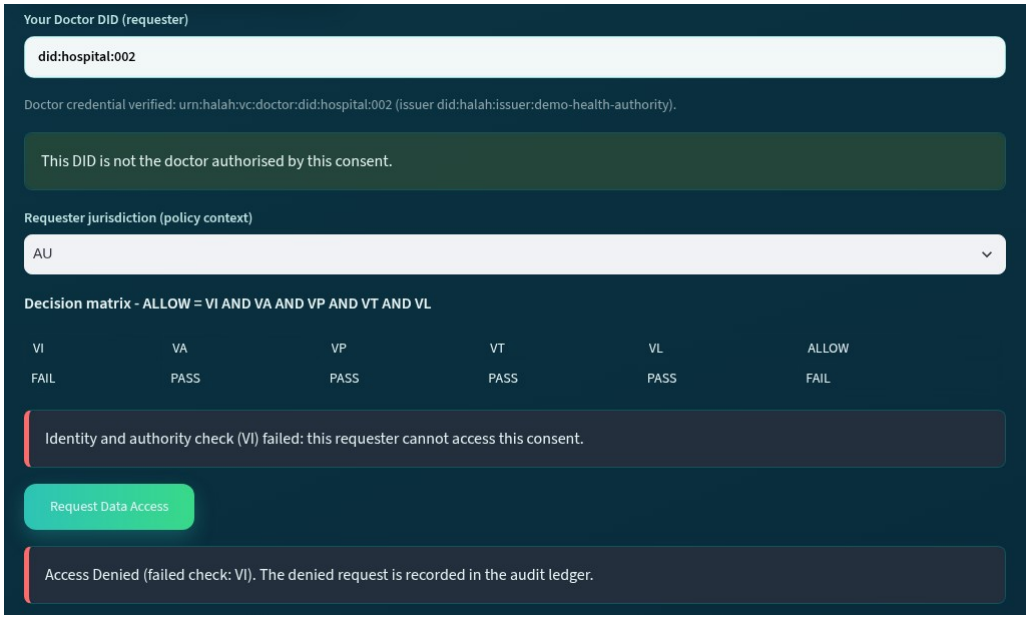


Figure 6.6: Doctor interface for a requester with a valid credential who is not the doctor named in the consent

6.7 Prototype Validation and Discussion

Objective two involves the verification of the identity and the authority of a participant as two separate conditions. The result of RO2 is therefore the verification model of Sections 6.3 to 6.5 and its predicate VI, not a set of measurements. The prototype results reported in this section show that the model can be realised and behaves as specified, so they are reported as outcomes, verified or refused, rather than as numbers; the quantitative evaluation of the complete framework is given in Chapter 10. RO2 is validated in three ways: through the live run of the prototype, through the automated tests of the credential check, and through the adversarial scenario A12, and the results are brought together in Table 6.1.

6.7.1 Validation of Identity and Authority Verification

Live scenario. In the local run of 11 October 2026 on the consent 18ab9b62, whose creation was reported in Chapter 5, the guardian did:parent:A approved at 17:41:45 and the guardian did:parent:B at 17:41:53. Each approval was accepted only after the

guardian credential had been verified, and the ledger row of each approval holds the credential identifier, urn:halah:vc:guardian:did:parent:A and urn:halah:vc:guardian:did:parent:B, and the issuer did:halah:issuer:demo-health-authority (Figure 6.5). A request was then made with the DID did:hospital:002, which holds a valid doctor credential but is not the doctor named in the consent. The decision matrix recorded VI = FAIL with the other four checks passed, and the request was refused at 17:42:04 with the result DENIED and the DID and credential of the requester written to the ledger (Figure 6.6). The same request made with did:hospital:001, the authorised doctor, passed VI at 17:42:19 and was granted at 17:42:21. This is the positive control: the same consent, the same credential store and the same checks, with only the requester changed. At creation, in the same run, a doctor DID without a valid doctor credential and a guardian DID without a valid guardian credential had been rejected before the consent was stored, as reported in Section 5.9.1.

Before and after the credential check. Before the credential check was added on 11 October 2026, the identity check accepted any string that began with did:. A probe of the decision function with three inputs, a doctor DID with no credential, two DIDs typed into one field, and a guardian DID used as the doctor, returned VI = PASS and ALLOW for all three. After the change, the same probe returns VI = FAIL and DENY for all three. The design of Section 6.5 was therefore correct before the change, but its implementation was not, which is the kind of gap that the validation of each objective is meant to find.

Automated tests. Five tests cover the credential check. The test test_demo_credentials_verify_and_are_reproducible asserts that each guardian credential verifies for the role guardian and fails for the role doctor, that each doctor credential verifies for the role doctor and fails for the role guardian, and that a stored credential equals the one the issuer produces for the same DID and role. The test test_each_credential_condition_fails_on_its_own alters one condition at a time, a claim changed after signing, an unknown issuer, the credential of another subject, a check dated after the validity period, the wrong role, and a DID with no credential, and asserts that each condition fails on its own. The test test_did_syntax asserts that nine malformed identifiers are refused. The test test_vi_binds_the_requester_to_the_consent_doctor asserts that a valid doctor who is not the doctor of the consent fails VI, and the test test_credential_time_follows_the_evaluation_time_and_bad_fields_fail_closed asserts that a credential is refused when the evaluation time lies after its validity period and that a malformed credential object is refused rather than accepted. The adversarial scenario A12, invalid or forged credential (test_A13_invalid_or_forged_credential_is_rejected), presents a credential signed by a key that is not the issuer's, a credential from an untrusted issuer, a guardian credential whose role claim was changed to doctor, the credential of another DID and an expired credential, and asserts that each fails VI and gives DENY; it also refuses a guardian posing as the doctor, a valid doctor not named in the consent, and a well-formed DID with no credential. All of these tests pass in the suite of 46 reported in Chapter 10, and the credential check takes about 6 ms per credential, as measured in Chapter 10.

Table 6.1 brings these results together by condition of the verification model. For each condition it gives the step of the procedure and the lines of Algorithm 2 that apply it, the evidence from the live run and the automated tests, and the result observed.

Table 6.1: Validation results of the prototype for identity and authority verification

Condition	Check (procedure step and Algorithm 2 lines)	Evidence	Result
DID syntax	Steps 1 and 2 (Algorithm 2, lines 1 to 8), reduced in this stage to the syntax did:method:identifier.	Test test_did_syntax: nine malformed identifiers refused, among them an empty string, a missing method, an upper-case method and a space inside the identifier. Run of 11 October 2026: two DIDs typed into one field refused (Section 5.9.1).	Malformed identifiers refused; well-formed identifiers pass to the credential check.
Credential found	Step 3 (lines 9 to 12): a credential for the DID must exist in the credential store.	A well-formed DID with no credential, did:hospital:999, fails VI (tests test_each_credential_condition_fails_on_its_own and A12).	No credential, no participation.
Signature	Step 4 (lines 13 to 16): the signature must recover to the registered address of the issuer.	A claim changed after signing (validUntil moved to 2099) fails the signature condition; a credential signed by a key that is not the issuer's is refused (A12).	Tampered and forged credentials refused.
Issuer	Step 4: the issuer must be in the trusted-issuer registry.	A credential from did:example:other and one from an unknown issuer fail the issuer condition (tests and A12).	Untrusted issuers refused.
Subject	Step 4: the subject of the credential must be the DID presented.	The credential of did:hospital:002 presented for did:hospital:001 fails the subject condition (tests and A12).	A credential cannot be borrowed by another DID.
Validity period	Step 4: the time of the check must lie between validFrom and validUntil.	A check dated 1 January 2031, after the validUntil of the demo credentials, fails; an expired credential is refused (A12); the check follows the evaluation time passed to the decision function.	Expired credentials refused.
Role	Steps 5 and 6 (lines 17 to 20): the role claim must be the role the step requires.	A guardian credential presented as a doctor fails the role condition; a guardian posing as the doctor is refused (A12). Each guardian credential verifies as guardian and fails as doctor, and each doctor credential the reverse.	Wrong role refused.
Binding to the consent	Steps 6 and 7: the doctor must be the authorised doctor named in the consent.	Run of 11 October 2026: did:hospital:002 holds a valid doctor credential but is not the doctor of consent 18ab9b62; VI = FAIL, request DENIED at 17:42:04 (Figure 6.6). Test test_vi_binds_the_requester_to_the_consent_doctor.	A valid doctor is refused on a consent that does not name them; did:hospital:001 passed VI at 17:42:19.
Evidence	Step 8 (line 21): the verification evidence is recorded.	Ledger rows of the approvals at 17:41:45 and 17:41:53 carry the credential identifier and the issuer; the STATE_CHECK and DATA_ACCESS rows of 17:42:04 and 17:42:19 carry the requester DID and its credential.	Every approval and every decision is traceable to a credential.

6.7.2 Discussion

The use of decentralised identifiers and verifiable credentials for identity and authority verification has several advantages which include separation, evidence, and independence from a central identity provider. Separation means that the identity of a participant and the authority of that participant are two checks, so a valid identity never gives access by itself, and a credential never gives access to a consent that does not name its holder. Evidence means that every approval and every decision carries the credential

identifier and the issuer, so an auditor can see on whose authority a guardian signed or a doctor was refused. Independence means that the verifier needs only the registered address of the issuer and not a connection to it, so a credential issued by one healthcare authority can be checked by any HALAH instance that trusts that authority.

On the other hand, the trade-offs are the dependence on the issuer and the limits of this stage. A credential is only as trustworthy as its issuer, and the current check has no credential revocation list, so a credential withdrawn by its issuer remains valid until its validUntil time. The DID is checked for its syntax and not resolved, and the DID of the requester is entered rather than authenticated, so VI shows that the DID entered holds a valid doctor credential and is the doctor named in the consent, not that the person at the interface controls that DID. Although these may be considered limitations of the method, the certainty that no participant takes part without a credential of the right role from a trusted issuer outweighs them at this stage, and DID resolution, holder binding and wallet-held keys are addressed in the next stage of the research, as discussed in Chapter 11.

6.8 Conclusion

In this chapter, we discussed decentralised identifiers and verifiable credentials and used them to verify who a participant is and what authority the participant holds as two separate conditions. In particular, we presented the principle that identity is not authorisation, the verification condition $\mathrm{VI}(u) = \mathrm{VerifyDID}(u) \wedge \mathrm{VerifyVC}(u) \wedge \mathrm{Authority}(u, C)$, the nine-step verification procedure and Algorithm 2, in which a credential is valid only when its signature, issuer, subject and validity period are all verified and its role claim matches the role that the consent requires. This addressed the second research objective of this thesis.

In this chapter we also presented the realisation of the verification in the HALAH prototype and the results of its validation. At the end of the validation process, the results show that a guardian signs only after the guardian credential has been verified, that a doctor who holds a valid credential but is not the doctor named in the consent is refused before any record is shown, and that forged, tampered, expired, untrusted and misdirected credentials are refused one condition at a time. However, a key finding from the validation was that the prototype verifies the credential of the DID entered, not that the user controls that DID; holder binding and DID resolution are the work of the next stage.

The next chapter will discuss in a methodological manner the steps involved in the multi-party approval of the consent by the guardian set, which is the solution for research objective 3.